



Madhya Pradesh State Electronics Development Corporation Limited

(A CERT-In empaneled Org. under Dept. of Science & Technology, Govt. of MP)

CERTIFICATE FOR WEBSITE SECURITY AUDIT

Department

Department of Science and Technology, Govt. of M.P.

Testing URL

<https://gisuat.mp.gov.in/Jalnigam/web/Login>

Production URL

jalrekha.mp.gov.in

Project/ Website Name

Jal Rekha

Software Build Number

jalrekha_112

Software Build Date

30th October 2025

Audit Performed by

MPSEDC, Security Testing Team

Testing Start Date

9th September 2025

Testing End Date

12th November 2025

Observation

The above website/application has undergone the Security Audit and has been certified to be safe from vulnerabilities as per OWASP Top 10-2021 compliance. A temporary testing URL was provided to execute the security audit.

Conclusion

The website/application was tested for OWASP Top 10-2021 vulnerabilities. The site is free from OWASP Top 10-2021 vulnerabilities and safe for web hosting.

Recommendations

1. TLS deployment is recommended so that confidentiality, integrity, and non-repudiation of the transactions for the application are ensured.
2. Web Server and OS Level hardening must be in place for the production server.

Note: The certificate is valid till no additional changes in the dynamic content or source code are carried out or one year from the date of issue whichever is earlier. Additionally, the auditee is responsible for deploying the audited solution to the production environment.

Disclaimer: The audit was NOT conducted on the Production Environment.

For MPSEDC
(Anshuman Raj)

PD, SWAN
(Anshuman Raj, IAS)

Project Director
MPSEDC, BHOPAL (M.P.)

(A State IT Center, 47th A, Arera Hills, Bhopal-462011 | Phone: +91-755-2518710 | Email: security.audit@mp.gov.in)

Date of issue: 26/11/2025

Certificate No: MPSEDC/COESA/ 957

Reference No: MAPIT-SA-202510354

Audited Application Hash Value: A72725482606FA64D6AFF9ABBCF3AC89

Client Report

Report Release Date	12 th November 2025
Type of Audit	Website Security Audit
Type of Audit Report	Final Audit Report
Period	9 th September 2025 to 12 th November 2025

Document Control

Document Preparation	
Document Title	Department of Science and Technology Application SA Report
Document ID	MAPIT-SA-202510354
Document Version	Final
Prepared by	Abhishek Shroti
Reviewed by	Sourabh Singh Rathore Vishal Shukla Priyank Soni
Approved by	Ambar Pande
Released by	Rupal Rathore
Release date	12 th November 2025

Document Change History		
Version	Date	Remarks / Reason of change
1.0	12 th November 2025	All

Document Distribution List

Name	Organization	Designation	Email Id
Mr. Ajay Jain	MPSED	Developer	thakur.sunil@mp.gov.in
Mr. Vinay Pandey	MPSED	Deputy Director	vinay.pandey@mp.gov.in
Mr. Ambar Pande	MPSED	PC	ambar.pande@mp.gov.in

Note: As per the directive received from CERT-In, MeitY, Gol, this report is confidential and should only be shared with designated authorized appointed by the Auditee/Auditor along with CERT-In.

Contents

Executive Summary of Security Audit for the MP Science & Public Health & Family Welfare Department Application	4
Introduction	5
Engagement Scope	6
Details of the Auditing team	7
Audit Activities and Timelines	8
Audit Methodology and Criteria / Standard referred for audit	9
Tools/ Software used	10
Executive Summary	11
Detailed Observations	13
Appendices	16

Executive Summary of Security Audit for the MP Science & Technology Dept. – MPSEDC Jal Rekha Application

Objective:

A comprehensive security audit was conducted on the Jal Rekha MPSEDC Department Application to identify vulnerabilities and ensure its security posture before deployment. This report provides an overview of the vulnerabilities detected and subsequent remediation actions.

Audit Findings:

The vulnerabilities identified were categorized into critical, moderate, and low severity, with notable issues including:

- 1. Cross-Site Request Forgery (CSRF):**
Multiple endpoints were vulnerable to CSRF attacks, potentially allowing unauthorized actions to be performed on behalf of authenticated users.
- 2. Cleartext Submission of Passwords:**
It was observed that sensitive information, including passwords, was transmitted in plaintext, making it susceptible to interception by attackers during transmission.
- 3. Vulnerable JavaScript Dependencies:**
Outdated or insecure JavaScript libraries were in use, posing a risk to the application's integrity by exposing it to known exploits within these dependencies.

Remediation Actions:

All identified vulnerabilities have been addressed with the following corrective actions:

- CSRF Protections:**
Implemented CSRF tokens and secured headers to prevent unauthorized actions via CSRF attacks.
- Encryption of Sensitive Data:**
All sensitive data, including passwords, is now encrypted during transmission using industry-standard protocols (e.g., HTTPS, TLS), ensuring confidentiality and data integrity.
- Updated JavaScript Libraries:**
The vulnerable JavaScript dependencies have been replaced or updated to their latest secure versions, mitigating the risk of exploitation.

Conclusion:

The Department of Science and Technology - Public Health & Family Welfare Department Application has undergone a thorough security review, and all identified vulnerabilities have been successfully resolved. The application is now considered secure and safe for hosting and use. Regular security audits and updates are recommended to maintain this security posture and to address any future vulnerabilities proactively.

Next Steps:

- Continuous monitoring of the portal's security.
- Scheduled periodic audits to ensure ongoing compliance with security best practices.

Introduction

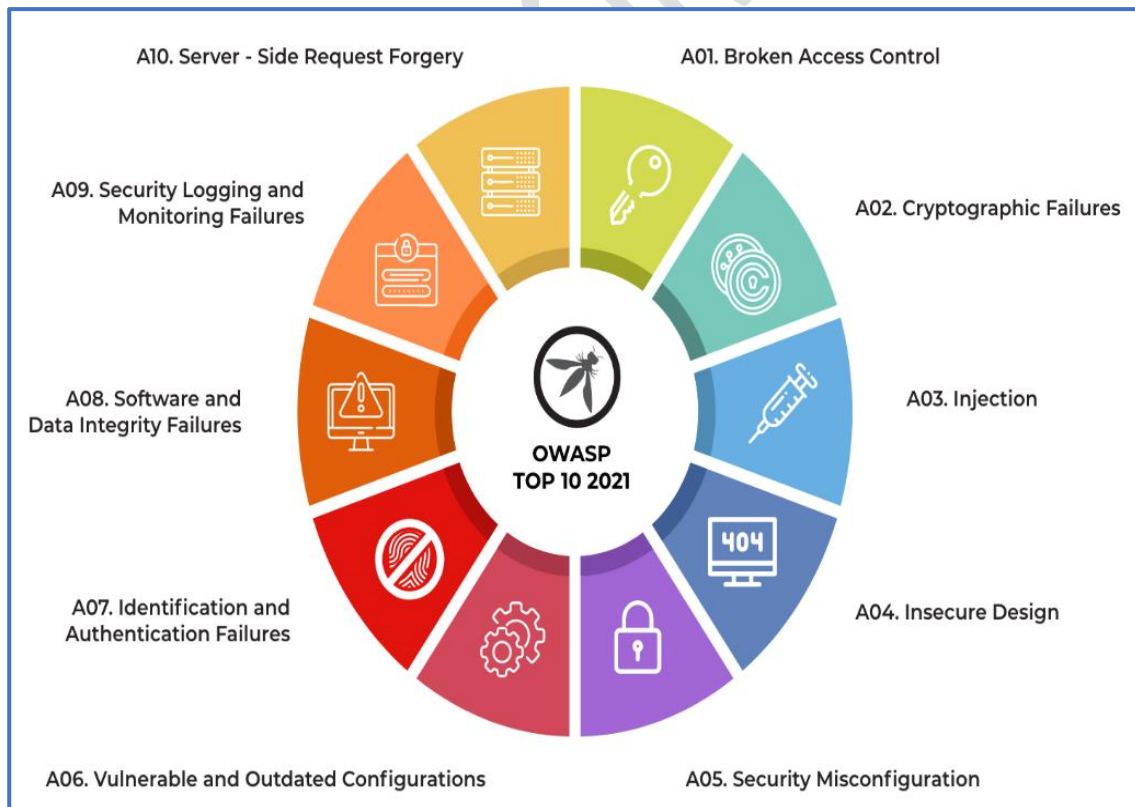
Brief Introduction about the Audit engagement along with the below details:

The Open Web Application Security Project (OWASP Top 10-2021) standard was used to test the application with the Test URL:

'<https://gisuat.mp.gov.in/Jalnigam/web/Login>'

The OWASP Top 10 -2021 represents a broad consensus about the most critical application security flaws. The OWASP Top 10- 2021 Most Critical Application Security Vulnerabilities are as follows:

OWASP Top 2021



Engagement Scope

<Below details of assets (whichever is/are applicable based on the type of audit) covered in the scope be included in this section along with other relevant details:>

S. No	Asset Description	Criticality of Asset	Internal IP Address	URL	Public IP Address	Location	Hash Value (in case of applications)	Version (in case of applications)	Other details such as make and model in case of network devices or security devices.
1			10.11 5.195. 173	https:// gisuat.m p.gov.in /JalRekha/Login	103.9 4.204. 164		A7272548 2606FA64 D6AFF9A BBCF3AC 89	JalRk ha_30 10202 5_112	

Date up to which the list has been updated: dd.mm.yyyy (to be shared by Auditee organization with the Auditing organization before commencing the audit assignment)

Details of the Auditing team

S. No	Name	Designation	Email Id	Professional Qualifications/ Certifications	Whether the resource has been listed in the Snapshot information published on CERT-In's website (Yes/No)
1	Ambar Pande	Principal Consultant	ambar.pande@mp.gov.in	PMP, ISMS-LA (ISO 27001), SCM	Yes
2	Priyank Soni	Security Test Engineer	priyank.soni@mp.gov.in	ISMS-LA (ISO 27001), CEH, CompTIA CySA+	Yes
3	Sourabh Singh Rathore	Security Test Engineer	rathore.sourabh@mp.gov.in	ISMS-LA (ISO 27001), CEH, ECIH	Yes
4	Abhishek Shroti	Security Test Engineer	abhishek.shroti@mp.gov.in	CISA, PMP, CASP+, CPSA, ECSA, AZ-500, Fortinet NSE1, Fortinet NSE2, ICSI CNSS, ISMS-LA (ISO 27001), CEH	No
5	Vishal Shukla	Security Test Engineer	vishal.shukla07@mp.gov.in	CISM, CASP+, CPSA, ISMS-LA (ISO 27001), ECSA, ICSI CNSS, CEH	NO

Audit Activities and Timelines

<Details of Audit phases along with timelines to be captured in this section>

Security Testing Level	No. of Bugs					Date
	High	Medium	Low	Info	Total	
Level 1	0	1	6	0	7	09-09-2025
Level 2	0	0	0	0	0	12-11-2025

Audit Methodology and Criteria / Standard referred for audit

This report documents the findings of the Web Application Security Audit Level -1/2/3/Final) for the website '<https://gisuat.mp.gov.in/Jalnigam/web/Login>'. The test aimed to discover the vulnerabilities that malicious users can exploit. The section below describes the OWASP Top 10-2021 vulnerabilities.

The OWASP Top 10 (2021) for the Web Applications

S. No	Vulnerabilities	Status (Safe/ Unsafe/NA)
A1:2021	Broken Access Control	Safe
A2:2021	Cryptographic Failures	Safe
A3:2021	Injection	Safe
A4:2021	Insecure Design	Safe
A5:2021	Security Misconfiguration	Safe
A6:2021	Vulnerable and Outdated Components	Safe
A7:2021	Identification and Authentication Failures	Safe
A8:2021	Software and Data Integrity Failures	Safe
A9:2021	Security Logging and Monitoring Failures	Safe
A10:2021	Server-Side Request Forgery	Safe

Tools/ Software used

S. No	Name of Tool/Software used	Version of the tool /Software used	Open Source/Licensed
1	Nessus	10.6.1	Free Trail
2	Open VAS	23.2.0	Open Source
3	Nmap	7.95	Open Source
4	Metasploit	6.4.6	Open Source
5	Hydra - GTK	9.5	Open Source
6	Vulns	0.25.2	Open Source
7	Legion	0.4.3	Open Source
8	Linux Priv Checker	1.0	Custom
9	Angry IP Scanner	3.9.1	Open Source
10	Open SSH	8.8.P1	Open Source
11	SQL Map	1.3.4	Open Source
12	Hping	3.0	Open Source
13	Nuclei	3.2.4	Open Source
14	Searchsploit	-	Open Source
15	HTTPx	0.27	Open Source
16	AMass	V4.2	Open Source
17	DIR Search	-	Open Source
18	DIR Buster	-	Open Source
19	Go Buster	V1.2	Open Source
20	Ffuf	V2.1.0	Open Source
21	Burpsuite Pro	V2024.4.1	Licensed

Executive Summary

S. No	Affected Asset i.e. IP/URL/Application etc	Observation/ Vulnerability title	CVE/CWE	Control Objective #	Control Name #	Audit Requirement #	Severity	Recommendation	Reference	New or Repeat observation
1.	https://gisuat.mp.gov.in/Jainigam/web/L	Cross-Site Request Forgery	CWE-352	N/A	N/A	N/A	High	The most effective way to protect against CSRF vulnerabilities is to include within relevant requests an additional token that is not transmitted in a cookie: for example, a parameter in a hidden form field.	https://cwe.mitre.org/data/definitions/352.html	Repeat Observation
2.	https://gisuat.mp.gov.in/Jainigam/web/	Cleartext submission of password	CWE-319	N/A	N/A	N/A	High	Applications should use transport-level encryption (SSL or TLS) to protect all sensitive communications passing between the client and the server.	https://cwe.mitre.org/data/definitions/319.html	Repeat Observation

3.	https://gisuat.mp.gov.in/Jalnigam/web/Log	Vulnerable JavaScript dependency	CWE-1104	N/A	N/A	N/A	Low	Develop a patch-management strategy to ensure that security updates are promptly applied to all third-party libraries in your application. Also, consider reducing your attack surface by removing any libraries that are no longer in use.	https://cwe.mitre.org/data/definitions/1104.html	Repeat Observation
----	---	----------------------------------	----------	-----	-----	-----	-----	---	---	--------------------

Applicable in case of compliance Audits such as ISO/IEC 27001:2022 Audit, PCI DSS audit, audit as per regulatory requirements/directions, or any other such audit that checks compliance against standards/guidelines/directions mandated/recommended by a regulator or government agency.

Detailed Observations

Please refer below snapshot for open vulnerabilities during the final phase of the security assessment. Due to the report size being too high, kindly refer to the below summary observation snapshot, if required we will share the detailed report, kindly let us know.

i. Cross-site request forgery (CSRF)

Field	Details
Affected Asset i.e. IP/URL/Application etc.:	https://gisuat.mp.gov.in/Jalnigam/web/Login
Observation/ Vulnerability title:	Cross-Site Request Forgery
Detailed observation / Vulnerable point:	Cross-site request forgery (CSRF) vulnerabilities may arise when applications rely solely on HTTP cookies to identify the user who has issued a particular request. Because browsers automatically add cookies to requests regardless of their origin, it may be possible for an attacker to create a malicious website that forges a cross-domain request to the vulnerable application.
CVE/CWE:	CWE-353
Control Objective #	N/A
Control Name #	N/A
Audit Requirement #	N/A
Severity:	High
Recommendation:	The most effective way to protect against CSRF vulnerabilities is to include within relevant requests an additional token that is not transmitted in a cookie: for example, a parameter in a hidden form field.
Reference:	https://cwe.mitre.org/data/definitions/352.html
New or Repeat observation:	Repeat Observation

ii. Cleartext Submission of Password

Field	Details
Affected Asset	https://gisuat.mp.gov.in/Jalnigam/web/Login
Observation/Vulnerability title	Cleartext submission of password
Detailed observation / Vulnerable point	Some applications transmit passwords over unencrypted connections, making them vulnerable to interception. To exploit this vulnerability, an attacker must be suitably positioned to eavesdrop on the victim's network traffic.
CVE/CWE	CWE-319
Control Objective #	N/A
Control Name #	N/A
Audit Requirement #	N/A
Severity	High
Recommendation	Applications should use transport-level encryption (SSL or TLS) to protect all sensitive communications passing between the client and the server.
Reference	https://cwe.mitre.org/data/definitions/319.html
New or Repeat observation	Repeat Observation
References to evidence / Proof of Concept	<pre> <!doctype html> <html lang="en" xmlns="http://www.w3.org/1999/xhtml" data-ng-app="dms"> <head> <meta charset="utf-8" /> <meta name="Referrer-Policy" value="no-referrer same-origin" /> <meta http-e ...[SNIP]... <div class="d-flex flex-column"> <form method="post" id="loginform" class="form-horizontal" role="form" action="/dms/login"> <div class="input-group mb-3 icnn"> ...[SNIP]... <input name="password" type="password" class="form-control" id="password" placeholder="Password" required="required" maxlength="20" autocomplete="off" /> </div> </pre>

iii. Vulnerable JavaScript dependency

Field	Details
Affected Asset	https://gisuat.mp.gov.in/Jalnigam/web/Login
Observation/Vulnerability title	Vulnerable JavaScript dependency
Detailed observation / Vulnerable point	The use of third-party JavaScript libraries can introduce a range of DOM-based vulnerabilities, including some that can be used to hijack user accounts like DOM-XSS.
CVE/CWE	CWE-1104
Control Objective #	N/A
Control Name #	N/A
Audit Requirement #	N/A
Severity	Low
Recommendation	Develop a patch-management strategy to ensure that security updates are promptly applied to all third-party libraries in your application. Also, consider reducing your attack surface by removing any libraries that are no longer in use.
Reference	https://cwe.mitre.org/data/definitions/1104.html
New or Repeat observation	Repeat Observation
References to evidence / Proof of Concept	We detected jquery version 1.11.1.min-77b456b31bdeb2680afc9ad539f79584, which has the following vulnerabilities: • CVE-2015-9251: 3rd party CORS request may execute • CVE-2015-9251: <code>parseHTML()</code> executes scripts in event handlers • CVE-2019-11358: <code>jQuery</code> before 3.4.0, as used in Drupal,Backdrop CMS, and other products, mishandles <code>jQuery.extend(true, {}, ...)</code> because of Object prototype pollution • CVE-2020-11022: <code>Regex</code> in its <code>jQuery.htmlPrefilter</code> sometimes may introduce XSS • CVE-2020-11023, CVE-2020-23064: passing HTML containing <code><option></code> elements from untrusted sources - even after sanitizing it - to one of <code>jQuery</code>'s DOM manipulation methods (i.e. <code>html()</code>, <code>append()</code>, and others) may execute untrusted code. • <code>jQuery 1.x</code> and <code>2.x</code> are End-of-Life and no longer receiving security updates https://github.com/jquery/jquery.com/issues/162

Applicable in case of compliance Audits such as ISO/IEC 27001:2022 Audit, PCI DSS audit, audit as per regulatory requirements / directions or any other such audit which checks compliance against standards/guidelines/directions mandated/recommended by a regulator or government agency.

Appendices

<This section should include evidences and additional information that supports the main body of the report, such as detailed tables, figures, or descriptions of audit tools and techniques used and glossary of terms for clarity.>

AUDIT REPORT FORMAT